

IS 435 Network & Security in Business

CALIFORNIA STATE UNIVERSITY, NORTHRIDGE

College of Business and Economics

NETWORK SECURITY ANALYSIS REPORT

Comprehensive Security Solution for California State University, Northridge

Field	Response
Student Name(s)	Tommy Takahashi, Chibike Okigbo, Adam Moreria, Ej Bazuaye
Student ID(s)	(Tommy Takahashi - 202133834), Chiuike Okigbo - 202221389), (Adam Moreria - 204420508), (Ej Bazuaye - 203038387)
Course	IS 435 Network & Security in Business
Instructor	Ziyang Zhang
Submission Date	May 7th, 2026
Classification	Confidential - Academic Use Only

1. Introduction

1.1 Purpose and Scope

This report presents a comprehensive network security analysis and security solution for California State University, Northridge (CSUN), with particular focus on campus-wide academic, administrative, identity, remote-access, collaboration, and data storage systems that support students, faculty, staff, and campus operations. The scope includes major enterprise systems, sensitive data assets, user populations, likely threats, risk ratings, and appropriate technical and managerial controls.

The goal is to identify the most important data and systems, explain the threats that could compromise them, and recommend practical controls that fit a large public university in Los Angeles with high student volume, large numbers of employees, cloud services, remote access, campus Wi-Fi, research activity, and public-facing digital services. The report intentionally follows the Westbridge University report skeleton but replaces the fictional case facts with CSUN-focused assumptions and public CSUN information where available.

1.2 Organizational Context

California State University, Northridge is a public comprehensive university in the San Fernando Valley. The California State University campus profile identifies Northridge as founded in 1958 and located on a roughly 353-acre campus about 15 miles from Los Angeles. Recent CSU profile data lists CSUN enrollment at about 36,960 students, while CSUN services and public IT pages show a mature enterprise environment that includes SOLAR administrative applications, Canvas, Duo MFA, GlobalProtect VPN, Box, Zoom, Microsoft services, and information security policies.

Attribute	Details
Organization	California State University, Northridge (CSUN)
Department / Division	University-wide environment with focus on College of Business and Economics user needs
Total Users	Approximately 36,960 students, plus faculty, staff, student workers, contractors, guests, alumni, vendors, and applicants
Campus Profile	Public comprehensive university; founded in 1958; roughly 353-acre campus in Northridge / San Fernando Valley
Key Systems	SOLAR Student Administration, SOLAR Human Resources, SOLAR Financials, Canvas, CSUN Portal / myNorthridge Portal, Duo MFA, GlobalProtect VPN, Confidential Box / myCSUNbox, Zoom, Microsoft 365/email, PeopleSoft / Common Management System, Qualtrics, Splunk, TOPdesk
Regulatory Environment	FERPA, California privacy and breach notification laws, CSU data classification requirements, PCI-DSS where payment cards are handled, GLBA where financial aid information is processed, HIPAA where health-related systems apply, contractual vendor obligations

2. Data & System Sensitivity Analysis

2.1 Data Discovery & System Inventory

The data discovery process began by grouping CSUN systems by business function, data type, likely user population, internet exposure, and authentication path. Systems tied to student records, HR/payroll, finance, identity, and remote access receive special attention because compromise of those systems can cascade across the university. The inventory below uses CSUN-public system names when available and adds reasonable network-placement assumptions for a campus security design.

System / Asset	Type	Likely Network / Location	Users / Scale
SOLAR Student Administration	Student information / records system, PeopleSoft-backed administrative application	Administrative data center / protected application zone; accessed through CSUN Portal and authorized staff workstations	Students, registrar, advisors, faculty, financial aid, admissions, authorized staff
SOLAR Human Resources	HR, employment, time, benefits, employee records	Administrative application zone; staff HR and management access	Faculty, staff, HR administrators, managers
SOLAR Financials / Common Finance System	Finance, purchasing, travel, budget, accounting workflows	Administrative application zone; finance and procurement access	Finance staff, department admins, approvers, budget managers
Canvas LMS	Cloud learning management system	Cloud SaaS, reachable from student, faculty/staff, and remote networks	Students, faculty, TAs, instructional support

CSUN Portal / myNorthridge Portal	Identity-fronted campus portal and self-service hub	Internet-facing portal integrated with SSO and campus applications	Students, applicants, faculty, staff
Duo MFA and Identity Services	Multi-factor authentication / access security layer	Cloud and campus identity infrastructure	Users accessing Duo-protected services
GlobalProtect VPN	Remote-access VPN	Network edge / remote access zone	Faculty, staff, student workers, administrators, IT support
Confidential Box / myCSUNbox	Cloud file storage and collaboration	Cloud SaaS; Confidential Box for Level 1/confidential data	Faculty, staff, departments, student workers
Microsoft 365 / Email / Collaboration	Email, calendars, Teams, cloud collaboration	Cloud SaaS integrated with campus identity	University-wide users
Zoom and HIPAA Zoom	Video conferencing and regulated-use collaboration	Cloud SaaS with higher-security option for HIPAA-related uses	Classes, offices, advising, telehealth or sensitive meetings where approved
Splunk / Security Logging	Security monitoring and log analysis	Security operations / restricted admin zone	IT security, system administrators
TOPdesk / IT Service Management	Help desk ticketing and asset/request workflows	Cloud or campus-hosted service management zone	IT staff, users requesting help
Research and Departmental Data Stores	Research data, grants, analytics, departmental file shares	Research network, cloud storage, departmental servers	Faculty researchers, graduate assistants, departments
Campus Wi-Fi and Student BYOD	Wireless access for personal devices	Student/BYOD VLANs and guest networks	Students, guests, visitors, events
IoT / Facilities / Physical Security Systems	HVAC, cameras, access control, environmental sensors, building systems	Facilities / IoT VLANs with restricted east-west access	Facilities, campus police, physical security, vendors
Public Web and DMZ Services	Public sites, web apps, exposed integrations	DMZ / cloud-hosted web infrastructure	Internet users, applicants, students, faculty, staff

2.2 Data Classification

CSUN uses CSU-style protected data concepts. For this report, a four-tier model is used to make the analysis easy to grade and map to controls: Restricted, Confidential, Internal, and Public. CSUN public guidance describes protected data levels and recommends secure handling, encryption, Duo MFA, VPN, and Confidential Box for sensitive data. The classification below translates those requirements into an operational security plan.

Tier	Example Data	Systems Holding This Data	Regulatory / Policy Framework
Restricted	Social Security numbers, student academic records, grades, financial aid data, payroll, tax forms, bank information, authentication secrets, medical or counseling data where applicable, payment card data	SOLAR Student Administration, SOLAR HR, SOLAR Financials, Duo/identity services, VPN, Confidential Box, department administrative shares, health-related systems	FERPA, GLBA, PCI-DSS where applicable, HIPAA where applicable, California privacy law, CSU/CSUN information security policy
Confidential	Non-public budgets, departmental planning, grant data, unpublished research, internal audits, vendor contracts, advising notes, disciplinary or case-management records	Confidential Box, Microsoft 365, department repositories, research drives, Qualtrics, TOPdesk, Splunk logs	CSU/CSUN data classification, contract terms, IP obligations, institutional policy
Internal	Routine internal emails, non-public procedures, IT configuration notes, meeting notes, operational reports, internal training materials	Microsoft 365, Teams, SharePoint/Box, IT service management, internal web pages	Acceptable Use Policy, internal governance, CSU security standards
Public	Published catalog information, event pages, public campus news, degree program descriptions, approved web content	Public web servers, catalog pages, public communications platforms	No special protection once approved, but integrity and availability still matter

2.3 Sensitivity Ratings for Key Systems

The sensitivity score uses a 1 to 5 scale: 1 means not sensitive and 5 means very sensitive. Scores consider confidentiality, integrity, availability, compliance exposure, and how much damage one compromised system could cause. Identity, administrative records, financial systems, and remote access score highest because they can become the campus master keys.

System	Platform / Vendor or Service	Sensitivity	Rationale
--------	------------------------------	-------------	-----------

SOLAR Student Administration	CSUN SOLAR / PeopleSoft administrative applications	5	Contains student records, grades, enrollment, advisement, financial aid touchpoints, and protected education records. Breach can trigger FERPA issues and student trust damage.
SOLAR Human Resources	SOLAR HR / PeopleSoft	5	Contains employee records, payroll, benefits, tax and employment data. Integrity and confidentiality are both mission-critical.
SOLAR Financials / Common Finance System	SOLAR Financials / CSU finance workflows	5	Supports purchasing, budgets, accounting, travel, approvals, and financial controls. Fraud or downtime harms operations and audit posture.
Duo MFA and Identity Services	Duo, SSO, directory services, campus identity	5	Controls access to the largest set of systems. A compromise can unlock SOLAR, VPN, Canvas, Box, email, and administrative apps.
GlobalProtect VPN	Palo Alto GlobalProtect VPN with Duo integration	5	Remote network entry point. Compromised VPN access can allow lateral movement if segmentation and device posture checks fail.
Confidential Box / myCSUNbox	Box cloud storage with CSUN controls	4	Stores departmental files and, for Confidential Box, Level 1/confidential data. Sharing mistakes can expose sensitive data.
Microsoft 365 / Email / Collaboration	Microsoft cloud services	4	Email is a primary phishing entry point and often stores documents, credentials, conversations, and attachments.
Canvas LMS	Instructure Canvas	4	Contains course activity, assignments, grades, and student/faculty interaction. SaaS controls help, but data and account risk remain significant.
Research and Department Data Stores	Department servers, cloud storage, research repositories	4	Contains unpublished research, grant data, human-subjects data in some cases, and departmental operating files.
Splunk / Security Logs	Splunk monitoring and log platform	4	Contains security telemetry and may reveal system details, usernames, IPs, incident evidence, and attack paths.
Zoom / HIPAA Zoom	Zoom cloud conferencing	3	Meetings may include advising, HR, health, or academic discussions. Risk depends on use case and meeting configuration.
Public Web / DMZ Services	Campus websites and public applications	3	Public by design, but defacement, phishing pages, or outages damage trust and can aid broader attacks.
IoT / Facilities Systems	Building automation, cameras, access control	3	Often less sensitive individually, but can become a bridge into networks or affect physical safety and operations.

3. Security Threat Analysis

3.1 Risk Rating Methodology

Risk Score = Likelihood (1-5) x Impact (1-5). Likelihood measures how probable the threat is in CSUN's environment, considering higher education threat patterns, internet exposure, user behavior, remote access, cloud dependency, and technical ease. Impact measures harm to confidentiality, integrity, and availability, plus regulatory, financial, academic, operational, and reputational consequences.

Rating	Description	Likelihood	Impact	Score Range
CRITICAL	Immediate major risk to operations or data	4-5 / 5	4-5 / 5	16-25
HIGH	Significant disruption likely without mitigation	3-4 / 5	3-4 / 5	9-15
MEDIUM	Moderate risk; manageable with planned controls	2-3 / 5	2-3 / 5	4-8

3.2 Individual Threat Assessments

T-01: Phishing & Spear-Phishing Attacks

Category	Likelihood	Impact	Risk Rating
Social Engineering	5 / 5	5 / 5	CRITICAL - Score 25
Field	Analysis		
Threat description	Attackers send fraudulent emails, texts, portal notifications, or Teams/Zoom-style lures to steal credentials, Duo approvals, payroll information, or convince users to open malware. CSUN has a large and constantly changing population of students, faculty, staff, applicants, and student workers, which makes social engineering the front door most attackers will try first.		

Threat actor(s)	External cybercriminals, credential brokers, opportunistic attackers, scammers targeting financial aid or payroll, and advanced actors interested in research data.
Vulnerable assets / VLANs	Microsoft 365/email, CSUN Portal, Duo, GlobalProtect VPN, Canvas, SOLAR Student Administration, SOLAR HR/Financials, Confidential Box, department endpoints.
Likelihood justification	Likelihood is 5 because phishing is cheap, scalable, and does not require the attacker to defeat firewalls first. CSUN also publicly offers guidance on phishing, Duo, malware, ransomware, and reporting, which confirms these are realistic campus risks.
Impact - Confidentiality	Email contents, attachments, student records, HR data, financial data, advising records, research files, and data reachable by the stolen account.
Impact - Integrity	Fraudulent payroll or vendor changes, grade manipulation, false financial requests, altered files, or malicious mailbox rules.
Impact - Availability	Account lockouts, help desk surges, email quarantine events, and incident containment can interrupt teaching and operations.
Regulatory consequence	FERPA, GLBA, California privacy law, CSU/CSUN policy violations, and breach notification duties if protected data is exposed.

T-02: Ransomware Attack

Category	Likelihood	Impact	Risk Rating
Malware / Cyber-Crime	4 / 5	5 / 5	CRITICAL - Score 20
Field	Analysis		
Threat description	Ransomware can begin through phishing, exposed remote access, stolen credentials, or vulnerable endpoints. Once inside, attackers attempt privilege escalation, lateral movement, data theft, and encryption of servers and shared drives. At CSUN, the highest concern is ransomware spreading from user devices to administrative systems, department shares, or research storage.		
Threat actor(s)	Ransomware-as-a-service affiliates, external cybercriminal gangs, credential brokers, and extortion groups.		
Vulnerable assets / VLANs	Faculty/staff endpoints, computer labs, VPN-connected devices, SOLAR support systems, Confidential Box sync clients, departmental file shares, research storage, backups, Active Directory/identity services.		
Likelihood justification	Likelihood is 4 because universities have many users and endpoints, many departments, decentralized technology, and high remote-access demand. Impact is 5 because payroll, registration, advising, course access, and operations could be disrupted at once.		
Impact - Confidentiality	Attackers increasingly steal data before encrypting it, exposing student, HR, finance, research, and departmental files.		
Impact - Integrity	Files and databases can be encrypted, corrupted, or restored from untrusted states.		
Impact - Availability	SOLAR-related services, file storage, help desk, academic systems, and department operations may be unavailable for days or weeks.		
Regulatory consequence	FERPA, GLBA, California breach notification law, contractual research and vendor obligations, and audit findings.		

T-03: Weak Authentication, Credential Stuffing, and MFA Fatigue

Category	Likelihood	Impact	Risk Rating
Authentication Security	4 / 5	5 / 5	CRITICAL - Score 20
Field	Analysis		
Threat description	Attackers use leaked passwords from other websites, password spraying, automated login attempts, or Duo push fatigue to access CSUN accounts. Verified Duo Push reduces blind approval risk, but attackers may still trick users during real-time phishing.		
Threat actor(s)	Credential stuffing bots, phishing kits, external cybercriminals, account takeover groups.		
Vulnerable assets / VLANs	Duo-protected services including Canvas, Confidential Box, myNorthridge/CSUN Portal, SOLAR HR/Student Administration, VPN GlobalProtect, Zoom, Splunk, TOPdesk, and Microsoft services.		
Likelihood justification	Likelihood is 4 because login portals are internet-accessible and password reuse is common across large populations. Impact is 5 because one privileged account can access sensitive administrative systems.		

Impact - Confidentiality	Data reachable through compromised account privileges: email, Box files, student records, HR/finance data, help desk records, and research documents.
Impact - Integrity	Unauthorized account changes, grade or advising manipulation, fraudulent workflows, altered files, malicious forwarding rules.
Impact - Availability	Account lockouts, Duo lockouts, emergency access revocation, and support volume spikes.
Regulatory consequence	FERPA, GLBA, state privacy requirements, CSU authentication standards, audit exceptions.

T-04: Unpatched Software and Vulnerability Exploitation

Category	Likelihood	Impact	Risk Rating
Vulnerability Management	4 / 5	4 / 5	CRITICAL - Score 16
Field	Analysis		
Threat description	Attackers scan for known vulnerabilities in VPN appliances, web apps, servers, endpoints, SaaS integrations, and network devices. If CSUN systems lag on patching or secure configuration, attackers can gain initial access or elevate privileges.		
Threat actor(s)	External attackers, ransomware groups, botnet operators, opportunistic scanners.		
Vulnerable assets / VLANs	GlobalProtect/VPN edge, public web/DMZ services, PeopleSoft/SOLAR interfaces, lab endpoints, faculty/staff laptops, servers, wireless infrastructure, cloud configurations.		
Likelihood justification	Likelihood is 4 because large universities run diverse technologies and attackers automate scanning. Impact is 4 because exploitation can open a path to identity services, protected systems, data theft, or service outages.		
Impact - Confidentiality	Compromised servers or apps may expose protected student, employee, finance, or research data.		
Impact - Integrity	Attackers may modify web content, manipulate application data, plant backdoors, or change permissions.		
Impact - Availability	Emergency patching, server compromise, or destructive exploitation can cause outages.		
Regulatory consequence	CSU/CSUN policy failures, FERPA or state breach obligations if sensitive data is exposed, audit findings.		

T-05: Unauthorized Access and Insider Threats

Category	Likelihood	Impact	Risk Rating
Access Control / Insider Risk	3 / 5	5 / 5	HIGH - Score 15
Field	Analysis		
Threat description	A current or former employee, student worker, contractor, or over-permissioned user intentionally or accidentally accesses data outside their role. Insiders are dangerous because they may already have valid credentials and understand campus processes.		
Threat actor(s)	Malicious insiders, negligent employees, student workers, former staff, compromised insiders, contractors.		
Vulnerable assets / VLANs	SOLAR Student Administration, SOLAR HR, SOLAR Financials, Confidential Box, Microsoft 365, department shares, research data, Splunk and TOPdesk records.		
Likelihood justification	Likelihood is 3 because malicious insiders are less common than phishing, but role changes, student employee turnover, and many administrative workflows make access drift likely. Impact is 5 because insiders may directly reach restricted systems.		
Impact - Confidentiality	Student education records, employee files, payroll, budget records, investigations, research, advising notes.		
Impact - Integrity	Unauthorized edits to records, grades, approvals, tickets, or research data.		
Impact - Availability	Targeted deletion, sabotage, or loss of trust in system data may interrupt operations.		
Regulatory consequence	FERPA, HR privacy duties, California privacy law, CSU/CSUN disciplinary and audit consequences.		

T-06: Data Leakage and Insecure Cloud Sharing

Category	Likelihood	Impact	Risk Rating
Data Security / Compliance	3 / 5	4 / 5	HIGH - Score 12

Field	Analysis
Threat description	Protected data can leak through misaddressed emails, public Box links, wrong permissions, unencrypted files, personal cloud accounts, shared Zoom recordings, or exports from SOLAR and other administrative tools. The danger is quiet: no malware required, just one badly aimed share link.
Threat actor(s)	Negligent users, compromised accounts, external recipients, opportunistic data collectors.
Vulnerable assets / VLANs	Confidential Box/myCSUNbox, Microsoft 365, email, Zoom recordings, Qualtrics exports, SOLAR reports, department file shares, research data stores.
Likelihood justification	Likelihood is 3 because CSUN provides Confidential Box and security guidance, but human error and cloud sharing misconfiguration remain common. Impact is 4 because restricted data can trigger legal and reputational consequences.
Impact - Confidentiality	Student records, HR/payroll, financial aid, research data, advising notes, internal investigation material.
Impact - Integrity	Editable links or exposed credentials can allow unauthorized changes to documents or data.
Impact - Availability	Investigations and remediation can disrupt departments, though leakage is mostly a confidentiality risk.
Regulatory consequence	FERPA, GLBA, HIPAA where applicable, California breach notification law, CSU/CSUN data classification requirements.

T-07: Third-Party and SaaS Supply Chain Risk

Category	Likelihood	Impact	Risk Rating
Third-Party Risk	3 / 5	4 / 5	HIGH - Score 12
Field	Analysis		
Threat description	CSUN depends on cloud and vendor services such as Canvas, Duo, Box, Zoom, Microsoft, Qualtrics, and PeopleSoft-related platforms. A vendor compromise, insecure integration, abused API key, or poor contract controls can bypass local defenses.		
Threat actor(s)	Compromised vendors, SaaS attackers, supply chain threat actors, negligent service providers.		
Vulnerable assets / VLANs	Canvas, Duo, Box, Microsoft 365, Zoom/HIPAA Zoom, Qualtrics, SOLAR integrations, API keys, SSO configurations.		
Likelihood justification	Likelihood is 3 because major vendors invest heavily in security, but universities rely on many integrations. Impact is 4 because one trusted vendor or token can expose many accounts or datasets.		
Impact - Confidentiality	Student data, file storage, meeting recordings, research data, logs, identity attributes.		
Impact - Integrity	Malicious integrations or updates could alter permissions, files, enrollment data exports, or application workflows.		
Impact - Availability	Vendor outage can disrupt classes, SSO, file access, meetings, forms, and support workflows.		
Regulatory consequence	FERPA, contract breach, data processing agreements, breach notification and vendor governance obligations.		

T-08: Rogue Access Points and Man-in-the-Middle Attacks

Category	Likelihood	Impact	Risk Rating
Wireless / Network Security	3 / 5	4 / 5	HIGH - Score 12
Field	Analysis		
Threat description	Attackers set up an evil-twin SSID, rogue AP, or malicious hotspot near campus buildings to capture logins or intercept traffic. Open campus spaces, public events, and BYOD-heavy usage increase the attack surface.		
Threat actor(s)	Nearby attackers, students experimenting, cybercriminals, malicious visitors.		
Vulnerable assets / VLANs	Campus Wi-Fi, guest networks, student BYOD, faculty/staff devices, login pages, VPN users, wireless controllers.		
Likelihood justification	Likelihood is 3 because public campus environments make rogue wireless easy to attempt. Impact is 4 because credential capture can become a path to protected services.		
Impact - Confidentiality	Credentials, session tokens, email, portal activity, Canvas activity, files if users ignore warnings.		
Impact - Integrity	Session hijacking or credential use could allow data changes under a legitimate account.		
Impact - Availability	Localized wireless disruption, deauthentication attacks, or user lockouts.		

Regulatory consequence	FERPA or privacy impact if captured credentials expose student or employee data; acceptable-use violations.
------------------------	---

T-09: Distributed Denial of Service (DDoS) and Internet Service Disruption

Category	Likelihood	Impact	Risk Rating
Network Availability	3 / 5	3 / 5	MEDIUM - Score 9
Field		Analysis	
Threat description		Attackers flood public websites, portals, VPN, or internet links to interrupt access. DDoS is less likely to expose data directly, but it can interrupt classes, registration windows, advising, payments, remote work, and public communications.	
Threat actor(s)		Botnet operators, hacktivists, extortion groups, disgruntled users.	
Vulnerable assets / VLANs		Public websites, CSUN Portal, VPN, Canvas access paths, DNS, internet edge, DMZ and cloud-hosted services.	
Likelihood justification		Likelihood is 3 because universities are visible targets, but cloud vendors and network providers can absorb some attacks. Impact is 3 because the primary harm is availability, not confidentiality or integrity.	
Impact - Confidentiality		Low direct exposure unless DDoS distracts responders from a second attack.	
Impact - Integrity		No direct alteration, though monitoring and logs may be overwhelmed.	
Impact - Availability		Portal, VPN, public website, payment pages, or online learning access can be degraded.	
Regulatory consequence		Service commitments, academic disruption, emergency communications concerns, reputational damage.	

3.3 Consolidated Risk Matrix

#	Threat	Likelihood	Impact	Score	Rating
T-01	Phishing & Spear-Phishing Attacks	5 / 5	5 / 5	25	CRITICAL
T-02	Ransomware Attack	4 / 5	5 / 5	20	CRITICAL
T-03	Weak Authentication, Credential Stuffing, and MFA Fatigue	4 / 5	5 / 5	20	CRITICAL
T-04	Unpatched Software and Vulnerability Exploitation	4 / 5	4 / 5	16	CRITICAL
T-05	Unauthorized Access and Insider Threats	3 / 5	5 / 5	15	HIGH
T-06	Data Leakage and Insecure Cloud Sharing	3 / 5	4 / 5	12	HIGH
T-07	Third-Party and SaaS Supply Chain Risk	3 / 5	4 / 5	12	HIGH
T-08	Rogue Access Points and Man-in-the-Middle Attacks	3 / 5	4 / 5	12	HIGH
T-09	Distributed Denial of Service (DDoS) and Internet Service Disruption	3 / 5	3 / 5	9	MEDIUM

The top remediation priorities are phishing, ransomware, weak authentication, and unpatched vulnerabilities. These threats are the most dangerous because they are not isolated events: phishing can steal credentials, stolen credentials can bypass VPN defenses, unpatched systems can provide initial access, and all of those paths can lead to ransomware or data theft. Insider risk is also serious because authorized access can reach sensitive SOLAR and HR/finance data even when perimeter defenses are working.

4. Security Solutions

Security solutions are paired as managerial and technical controls. Managerial controls create rules, accountability, training, and repeatable processes. Technical controls prevent, detect, or correct attacks through tools, configurations, and architecture. The controls below are mapped to each threat so that every recommendation has a clear risk-reduction purpose.

4.1 Solutions for Phishing & Spear-Phishing Attacks

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
---	------------------	-------------------------	-------------------	----------------

1	Mandatory Security Awareness Training	Run required phishing training for students, faculty, staff, and student workers. Include fake Duo prompts, payroll scams, financial aid scams, fake Canvas messages, and false IT ticket notices.	Information Security / HR / Academic Departments	NIST CSF PR.AT
2	Simulated Phishing and Coaching Program	Conduct regular simulations and coach repeat clickers. The goal is behavior improvement, not punishment, so users report suspicious messages faster.	Security Awareness Lead	NIST CSF PR.AT
3	Financial and Data Change Verification Policy	Require out-of-band verification before payroll routing changes, vendor payment changes, student record exports, or sensitive data transfers.	Finance / HR / Registrar / Department Admins	NIST CSF PR.IP

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Advanced Email Security and DMARC Enforcement	Preventive / Detective	Use anti-phishing policies, attachment sandboxing, URL rewriting, impersonation protection, SPF/DKIM/DMARC enforcement, and sender anomaly detection.	Microsoft 365 / Email	NIST CSF PR.DS
2	Phishing Report Button and SOC Triage	Detective	Add one-click reporting in Outlook and route suspicious messages to security monitoring for rapid blocking, takedown, and campus alerting.	Email users and security operations	NIST CSF DE.CM
3	Phishing-Resistant MFA for High-Risk Users	Preventive	Use Verified Duo Push, number matching, device trust, or FIDO2/security keys for administrators and Level 1 data users.	Duo, Portal, VPN, SOLAR, Box	NIST CSF PR.AC

4.2 Solutions for Ransomware Attack

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Ransomware Incident Response Playbook	Define first-hour roles, escalation paths, network isolation rules, legal notification steps, law enforcement contact points, and communications templates.	CISO / IT Security / University Communications	NIST CSF RS.RP
2	Quarterly Backup Restore Testing	Require restore tests for SOLAR-related data, identity services, file storage, research data, and department shares so recovery is proven before a crisis.	IT Operations / System Owners	NIST CSF RC.RP
3	Ransomware Tabletop Exercises	Run simulated ransomware exercises involving IT, registrar, HR, finance, police, legal, executive leadership, and academic continuity teams.	CISO / Emergency Management	NIST CSF RS.IM

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Endpoint Detection and Response	Preventive / Detective	Deploy EDR on staff endpoints, lab computers, servers, and privileged admin workstations to identify encryption behavior, malicious scripts, and lateral movement.	Endpoints, admin workstations, servers	NIST CSF DE.CM
2	Immutable Backups and Offline Recovery Copies	Corrective	Maintain immutable backups, cloud object lock, offline copies, and documented restore procedures for critical data.	SOLAR, Box exports, research data, AD, file shares	NIST CSF RC.RP
3	Network Segmentation and Admin Tiering	Preventive	Separate student/BYOD, faculty/staff, admin, server, research, IoT, and DMZ networks. Restrict lateral movement and require hardened admin paths.	Campus VLANs / zones	NIST CSF PR.AC

4.3 Solutions for Weak Authentication, Credential Stuffing, and MFA Fatigue

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Password and MFA Policy	Require long passwords, breached-password screening, no shared accounts, MFA for sensitive services, and stronger factors for privileged users.	CISO / IAM Team	NIST CSF PR.AC
2	Privileged Access Review	Review privileged access quarterly for SOLAR, VPN, Box admin, Splunk, TOPdesk, and server/network administration.	System Owners / IAM Team	NIST CSF PR.AC

3	Help Desk Identity Verification Procedure	Standardize account recovery and reset verification to prevent social engineering of the IT Help Center.	IT Help Center / IAM Team	NIST CSF PR.IP
---	---	--	---------------------------	----------------

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Adaptive MFA and Conditional Access	Preventive	Challenge risky logins based on impossible travel, new devices, bad IP reputation, TOR/VPN use, and high-risk applications.	Duo, SSO, VPN, Microsoft 365	NIST CSF PR.AC
2	Breached Password Detection	Preventive	Block known compromised passwords and force resets when accounts appear in breach corpuses.	All campus accounts	NIST CSF PR.AC
3	Rate Limiting and Credential Stuffing Alerts	Detective / Corrective	Throttle repeated failed logins, alert on password spraying, and automatically block suspicious sources.	Portal, VPN, Microsoft 365, Canvas SSO	NIST CSF DE.CM

4.4 Solutions for Unpatched Software and Vulnerability Exploitation

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Vulnerability Management Policy	Set patch timelines: critical vulnerabilities within 24-72 hours, high within 7-14 days, and medium during scheduled maintenance.	CISO / IT Operations	NIST CSF ID.RA
2	Emergency Change Path	Allow emergency security patches without waiting for normal approval cycles when active exploitation is likely.	Change Advisory Board	NIST CSF PR.IP
3	Asset Ownership Register	Assign owners for applications, servers, cloud resources, APs, network devices, and vendor integrations so nothing becomes orphaned.	IT Governance / Department IT	NIST CSF ID.AM

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Authenticated Vulnerability Scanning	Detective	Run routine scans against servers, endpoints, cloud assets, VPN, DMZ, and network devices. Prioritize internet-facing and administrative systems.	VPN, DMZ, SOLAR interfaces, servers	NIST CSF DE.CM
2	Patch Management Platform	Corrective / Preventive	Automate OS and third-party patch deployment with dashboards for compliance reporting and exception tracking.	Endpoints, lab computers, servers	NIST CSF PR.IP
3	Secure Configuration Baselines	Preventive	Use CIS-style baselines, disable unused services, require strong protocols, and monitor drift from approved configurations.	Servers, endpoints, network devices	CIS Controls

4.5 Solutions for Unauthorized Access and Insider Threats

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Least Privilege Access Policy	Grant access based on role and business need, not convenience. Sensitive systems require manager and data-owner approval.	Data Owners / IAM Team	NIST CSF PR.AC
2	Quarterly Access Certification	Registrar, HR, Finance, Research, and IT system owners certify access lists and remove stale privileges.	System Owners / Compliance	ISO 27001 A.9
3	Offboarding and Role-Change Checklist	Disable accounts, VPN, privileged access, tokens, Box sharing, and administrator rights within a defined time after separation or role change.	HR / IAM / Department Managers	NIST CSF PR.IP

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Role-Based Access Control	Preventive	Map job roles to permissions in SOLAR, Box, Microsoft 365 groups, TOPdesk, and department systems.	SOLAR, Box, M365, admin tools	NIST CSF PR.AC
2	User and Entity Behavior Analytics	Detective	Alert on unusual downloads, after-hours access, mass file activity, access from abnormal locations, or use outside a user's role.	SOLAR, Box, M365, Splunk logs	NIST CSF DE.CM

3	Privileged Access Management	Preventive / Detective	Use just-in-time admin elevation, separate admin accounts, session logging, and approval workflows for high-risk actions.	AD/identity, servers, network devices	NIST CSF PR.AC
---	------------------------------	------------------------	---	---------------------------------------	----------------

4.6 Solutions for Data Leakage and Insecure Cloud Sharing

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Data Classification and Handling Policy	Define how Restricted and Confidential data may be stored, transmitted, shared, exported, and destroyed. Reinforce Confidential Box for sensitive cloud storage.	Data Governance Committee	NIST CSF PR.DS
2	Data Steward Program	Assign stewards for student records, HR/payroll, finance, research, health-related data, and institutional data.	Registrar / HR / Finance / Research Office	NIST CSF ID.GV
3	Secure Sharing Training	Train users to avoid public links, wrong recipients, personal cloud storage, unencrypted exports, and sensitive Zoom recordings.	Information Security / Data Stewards	NIST CSF PR.AT

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Data Loss Prevention	Preventive / Detective	Monitor and block restricted data leaving through email, Microsoft 365, Box sharing, endpoints, and web uploads.	Email, Box, endpoints, M365	NIST CSF PR.DS
2	Encryption Enforcement	Preventive	Require TLS, VPN for remote access, encryption at rest, secure file transfer, and disable legacy plaintext protocols.	SOLAR access, VPN, files, research data	NIST CSF PR.DS
3	Cloud Sharing Guardrails	Preventive / Detective	Block public links for sensitive folders, expire shared links, require MFA for Confidential Box, and alert on risky sharing.	Confidential Box / myCSUNbox	NIST CSF PR.DS

4.7 Solutions for Third-Party and SaaS Supply Chain Risk

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Third-Party Risk Management Program	Require security reviews, data protection terms, breach notification clauses, and annual reassessment for vendors handling protected data.	Procurement / CISO / Legal	NIST CSF ID.SC
2	Vendor Data Classification Checklist	Classify what data is shared with Canvas, Duo, Box, Microsoft, Zoom, Qualtrics, and PeopleSoft integrations before approval.	Data Stewards / Procurement	NIST CSF ID.AM
3	Contractual Incident Notification Requirements	Require rapid notification, cooperation, evidence preservation, and data-return/destruction terms.	Legal / Procurement / CISO	NIST CSF ID.SC

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	SSO and Least-Privilege Integrations	Preventive	Use SAML/OIDC with scoped permissions, no shared vendor accounts, and regular review of application consent.	Duo, Canvas, Box, M365, Zoom	NIST CSF PR.AC
2	Vendor Log Integration	Detective	Ingest vendor logs from SSO, Box, Microsoft, VPN, Zoom, and other SaaS into Splunk/SIEM.	Cloud and SaaS platforms	NIST CSF DE.CM
3	API Key and Secrets Management	Preventive	Store vendor keys securely, rotate secrets, restrict scopes, and monitor abnormal API activity.	SaaS integrations, automation, cloud services	NIST CSF PR.DS

4.8 Solutions for Rogue Access Points and Man-in-the-Middle Attacks

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	Wireless Acceptable Use Policy	Prohibit personal routers, unauthorized APs, and rogue network gear in campus buildings. Define enforcement and reporting.	Network Team / Facilities / Housing	NIST CSF PR.PT

2	Wireless Security Awareness	Teach users to verify official SSIDs, avoid entering credentials on suspicious captive portals, and use VPN on public networks.	Information Security / Student Affairs	NIST CSF PR.AT
3	Physical Network Walkthrough Procedure	Schedule checks of classrooms, labs, offices, and conference areas for unauthorized devices.	Network Team / Facilities	NIST CSF DE.CM

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	Wireless Intrusion Prevention System	Detective / Preventive	Detect evil-twin SSIDs, rogue APs, deauthentication attacks, and suspicious wireless activity.	Campus wireless, BYOD, guest Wi-Fi	NIST CSF DE.CM
2	802.1X / Certificate-Based Network Access	Preventive	Require stronger authentication for managed staff devices and sensitive wired/wireless networks.	Faculty/staff networks and admin zones	NIST CSF PR.AC
3	WPA3 Enterprise and Segmented SSIDs	Preventive	Use strong encryption and separate student, guest, staff, IoT, and administrative wireless access.	Wireless controllers and APs	NIST CSF PR.PT

4.9 Solutions for Distributed Denial of Service and Internet Service Disruption

Managerial Solutions

#	Control / Policy	Description & Rationale	Responsible Party	Framework Ref.
1	DDoS Response Playbook	Define ISP contacts, cloud provider escalation, filtering decisions, DNS actions, status-page updates, and leadership communications.	Network Team / University Communications	NIST CSF RS.RP
2	Academic and Administrative Continuity Plan	Identify critical services and manual workarounds during registration, finals, payroll, or emergency communication windows.	IT Governance / Academic Leadership	NIST CSF ID.BE
3	Outage Communication Plan	Prepare alternate messaging channels for students, faculty, staff, applicants, and external stakeholders.	IT Communications / Emergency Management	NIST CSF RS.CO

Technical Solutions

#	Control / Tool	Control Type	Description & How It Works	Asset / Zone Protected	Framework Ref.
1	DDoS Scrubbing / CDN Protection	Corrective	Route attack traffic through ISP or cloud scrubbing and protect public sites with CDN/WAF services.	Internet edge, DMZ, public web	NIST CSF PR.PT
2	Rate Limiting and Edge Firewall Rules	Preventive	Limit abusive traffic to public services, VPN, DNS, and web apps without blocking legitimate users.	Edge firewalls, VPN, public services	NIST CSF PR.PT
3	Redundant Connectivity and Monitoring	Detective / Corrective	Monitor links, DNS, availability, and routing. Use failover plans for critical services and status pages.	WAN, cloud apps, portals	NIST CSF DE.CM

5. Conclusion

CSUN handles highly sensitive student, employee, financial, identity, research, operational, and cloud-hosted data. The highest-risk threats are phishing, ransomware, weak authentication, and unpatched vulnerabilities because they combine high likelihood with high impact and can chain together into larger incidents. For example, a phishing email can steal credentials, stolen credentials can access VPN or cloud storage, unpatched servers can help attackers elevate privileges, and the final stage may be ransomware or data theft.

The recommended security program is layered: prevent common attacks with MFA, segmentation, secure configuration, access reviews, and user training; detect failures with EDR, SIEM/Splunk monitoring, DLP, wireless intrusion detection, and vendor logs; and recover with immutable backups, tested incident response plans, and service continuity procedures. This layered approach protects CSUN's most sensitive data while keeping teaching, research, administration, student services, and public communication available.

References

Source	Use in Report
California State University campus profile for Northridge	Used for CSUN organizational context, founded date, campus location, approximate campus size, and enrollment figure.

CSUN Information Technology - Campus Information Security Guidelines	Used for CSUN-specific security program context, including security awareness, Duo MFA, phishing, malware, ransomware, VPN, encryption, FERPA, vulnerability management, and security incident reporting.
CSUN SOLAR service page and SOLAR Support pages	Used to identify SOLAR as administrative applications for student administration, finance, and human resources.
CSUN Services Requiring Duo MFA page	Used to identify Duo-protected CSUN services such as Canvas, Confidential Box, SOLAR HR, SOLAR Student Administration, GlobalProtect VPN, Zoom, Splunk, TOPdesk, and others.
CSUN GlobalProtect page	Used to identify GlobalProtect as CSUN remote access VPN and its Duo-related behavior.
CSUN myCSUNbox / Confidential Box pages	Used for cloud storage sensitivity and recommendation that confidential data belongs in Confidential Box rather than regular storage.
CSUN Protected Data and Information Protection pages	Used for data classification, sensitive data handling, and the need to protect student and employee data.
CSUN FERPA / Privacy Rights of Students in Education Records policy page	Used for regulatory context around student education records.
NIST Cybersecurity Framework and ISO/IEC 27001	Used as general framework references for Identify, Protect, Detect, Respond, Recover, access control, incident response, governance, and monitoring.